Information Security Policy

Document ID: IS-007 | Owner: Information Security | Effective date: 2026-01-01 | Version 1.0

This policy sets the baseline information security requirements for all employees, contractors, and systems at Nile Horizon Bank. It is a fictional policy for training purposes.

1. Data Classification

All data must be classified into one of four levels: Public, Internal, Confidential, or Restricted.

Restricted data includes payment card numbers, national ID numbers, account credentials, and authentication data. Restricted data must never be copied to personal devices, email attachments, or unapproved external services.

2. Access Control

Passwords must be at least 12 characters long. Passwords for privileged accounts must be changed every 90 days.

Multi-factor authentication is mandatory for all remote access and for all privileged accounts.

Access rights of privileged accounts are reviewed every quarter. Access rights of standard accounts are reviewed once a year.

3. Logging and Audit

Security and audit logs must be kept online for 12 months and then archived for a total of 5 years. Logs must not contain Restricted data in clear text.

4. Incident Reporting

Any suspected security incident must be reported to the Security Operations Centre (SOC) within 1 hour of detection. Critical incidents must be escalated to the Chief Information Security Officer within 2 hours.

5. Encryption and Secrets

Data at rest must be encrypted with AES-256. Data in transit must use TLS 1.2 or higher.

Secrets such as API keys and passwords must be stored in the approved secrets vault and must never be written in source code or configuration files committed to version control.

6. Secure Development

All code must be peer reviewed before release. Dependencies must be scanned for known vulnerabilities in the build pipeline. Production data must not be used in development or test environments unless it has been masked.

Third parties that access bank systems must sign a non-disclosure agreement and pass a security assessment before access is granted.